Documentation Test attaque exercice CTF

Contexte général

L’entreprise Ouvrez l’œil met en place des exercices internes visant à évaluer et renforcer les compétences techniques de ses collaborateurs en matière de sécurité des systèmes d’information.

Ces exercices s’inscrivent dans une démarche de prévention, de formation et d’amélioration continue, en simulant des situations réalistes pouvant être rencontrées en environnement professionnel.

Un environnement informatique simulé a été mis à disposition, représentant un système d’information d’entreprise volontairement vulnérable.

Ce système comprend :

- Un serveur accessible à distance
- Une application web
- Plusieurs éléments de configuration exposés

L’objectif est d’analyser cet environnement comme le ferait un technicien ou un auditeur en sécurité.

Vous intervenez en tant que technicien systèmes et réseaux stagiaire au sein de l’entreprise.

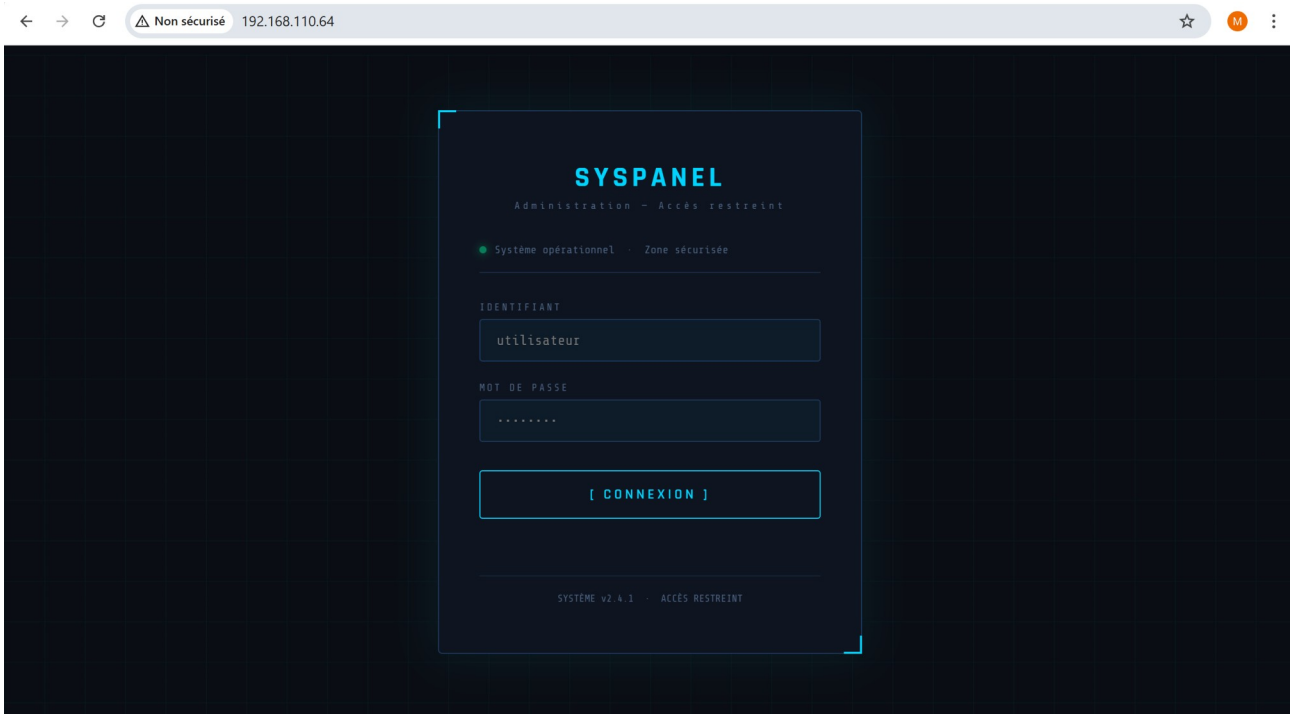
Votre mission consiste à :

- Analyser l’environnement mis à disposition
- Identifier d’éventuelles failles de sécurité
- Comprendre les mécanismes d’accès au système
- Reconstituer les différentes étapes permettant d’accéder aux ressources protégées

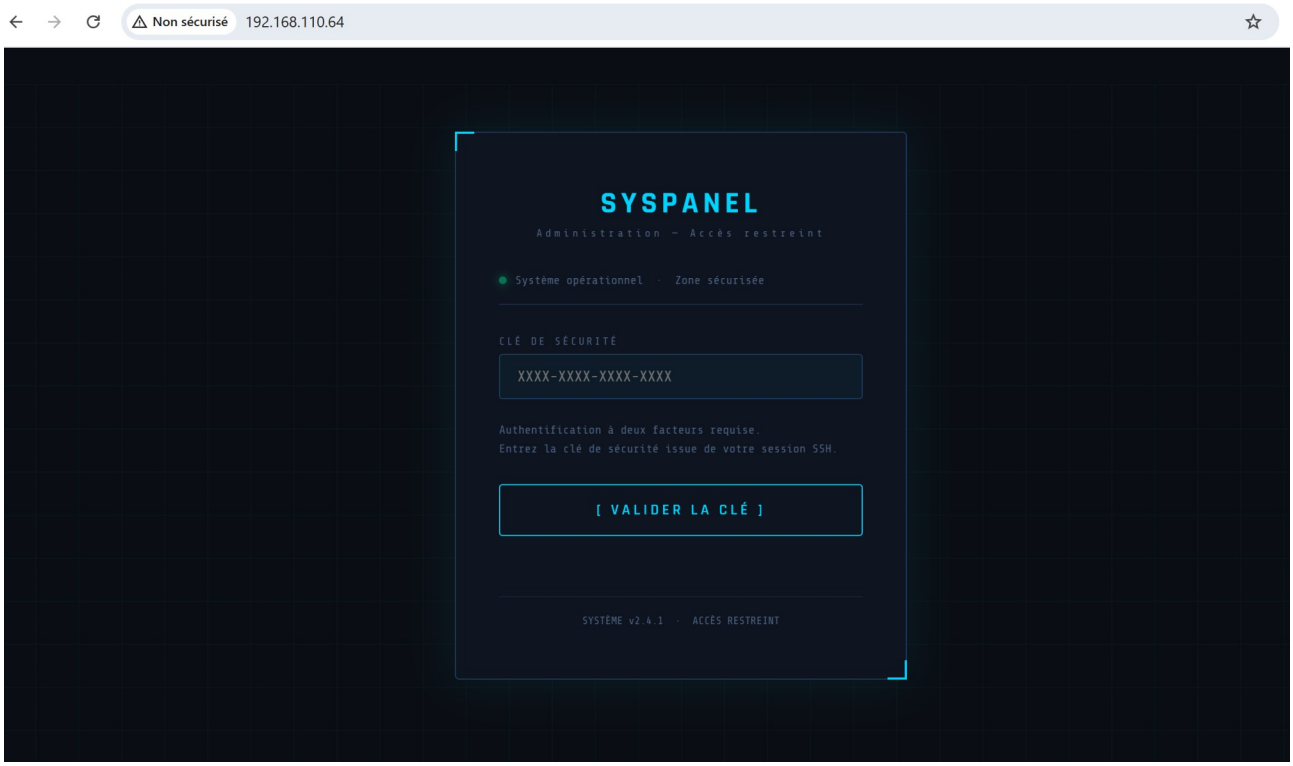
À l’issue de la mission, vous devrez être capable de :

- Présenter votre démarche d’analyse
- Expliquer les vulnérabilités identifiées
- Décrire les actions menées pour atteindre l’objectif
- Proposer des pistes d’amélioration en matière de sécurité

Pour l’attaque j’ai d’abord inspecter l’élément sur la page du site et j’y ai trouver l’identifiant et le mots de passe et après avoir rentrer les identifiants et mots de passe, on demande une clé de sécurité ssh que je devais trouver.




```
  <div class="footer-info">SYSTÈME v2.4.1  ·  ACCÈS RESTREINT</div>
</div>
<script>
  const PANEL_USER = "admin";
  const PANEL_PASS = "S3cur3P@nel!";
  let loginOk = false;

  function doLogin() {
    const u = document.getElementById('username').value.trim();
    const p = document.getElementById('password').value.trim();
    const err = document.getElementById('err-msg');
    if (u === PANEL_USER && p === PANEL_PASS) {
      document.getElementById('login-form').style.display = 'none';
      document.getElementById('key-form').style.display = 'block';
      loginOk = true;
    } else {
      err.textContent = '⚠ Identifiants incorrects — accès refusé';
      setTimeout(() => err.textContent = '', 3000);
    }
  }
```



Ensuite j'ai essayer de me connecter en ssh à l'adresse IP mais la connexion avec le port 22 a été refusée donc j'ai du chercher le bon port à trouver avec la commande nmap.

```
└─$ nmap -p0- -v -A -T4 192.168.110.64
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 09:35 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 09:35
Completed NSE at 09:35, 0.00s elapsed
Initiating NSE at 09:35
Completed NSE at 09:35, 0.00s elapsed
Initiating NSE at 09:35
Completed NSE at 09:35, 0.00s elapsed
Initiating Ping Scan at 09:35
Scanning 192.168.110.64 [4 ports]
Completed Ping Scan at 09:35, 0.02s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 09:35
Completed Parallel DNS resolution of 1 host. at 09:35, 0.01s elapsed
Initiating SYN Stealth Scan at 09:35
Scanning test.lan (192.168.110.64) [65536 ports]
Discovered open port 80/tcp on 192.168.110.64
Discovered open port 2277/tcp on 192.168.110.64
SYN Stealth Scan Timing: About 22.42% done; ETC: 09:37 (0:01:47 remaining)
SYN Stealth Scan Timing: About 57.72% done; ETC: 09:37 (0:00:45 remaining)
Completed SYN Stealth Scan at 09:37, 89.82s elapsed (65536 total ports)
Initiating Service scan at 09:37
Scanning 2 services on test.lan (192.168.110.64)
Completed Service scan at 09:37, 6.05s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against test.lan (192.168.110.64)
Retrying OS detection (try #2) against test.lan (192.168.110.64)
Initiating Traceroute at 09:37
Completed Traceroute at 09:37, 0.01s elapsed
NSE: Script scanning 192.168.110.64.
Initiating NSE at 09:37
Completed NSE at 09:37, 5.06s elapsed
Initiating NSE at 09:37
Completed NSE at 09:37, 0.06s elapsed
Initiating NSE at 09:37
Completed NSE at 09:37, 0.00s elapsed
Nmap scan report for test.lan (192.168.110.64)
Host is up (0.0012s latency).
Not shown: 65533 filtered tcp ports (no-response), 1 filtered tcp ports (net-unreach)
PORT     STATE SERVICE VERSION
80/tcp   open  http    nginx 1.24.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD
|_http-title: SysAdmin Panel \xE2\x80\x94 Connexion
| http-robots.txt: 3 disallowed entries
|_/admin/ /backup/ /config/
|_http-server-header: nginx/1.24.0 (Ubuntu)
2277/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 5b:8c:75:a4:f3:53:e3:fe:0c:05:5b:da:ff:8e:4a:d0 (ECDSA)
|_  256 bf:99:b8:b1:52:91:1e:b4:88:d6:b5:e3:27:11:2c:4e (ED25519)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
```

Après avoir trouver le port pour me connecter en ssh a l'adresse IP il me fallait trouver les identifiants pour la connexion ssh et pour cela j'ai donc attaquer l'URL avec l'outil gobuster qui est un outil similaire a hydra mais pour les URL.

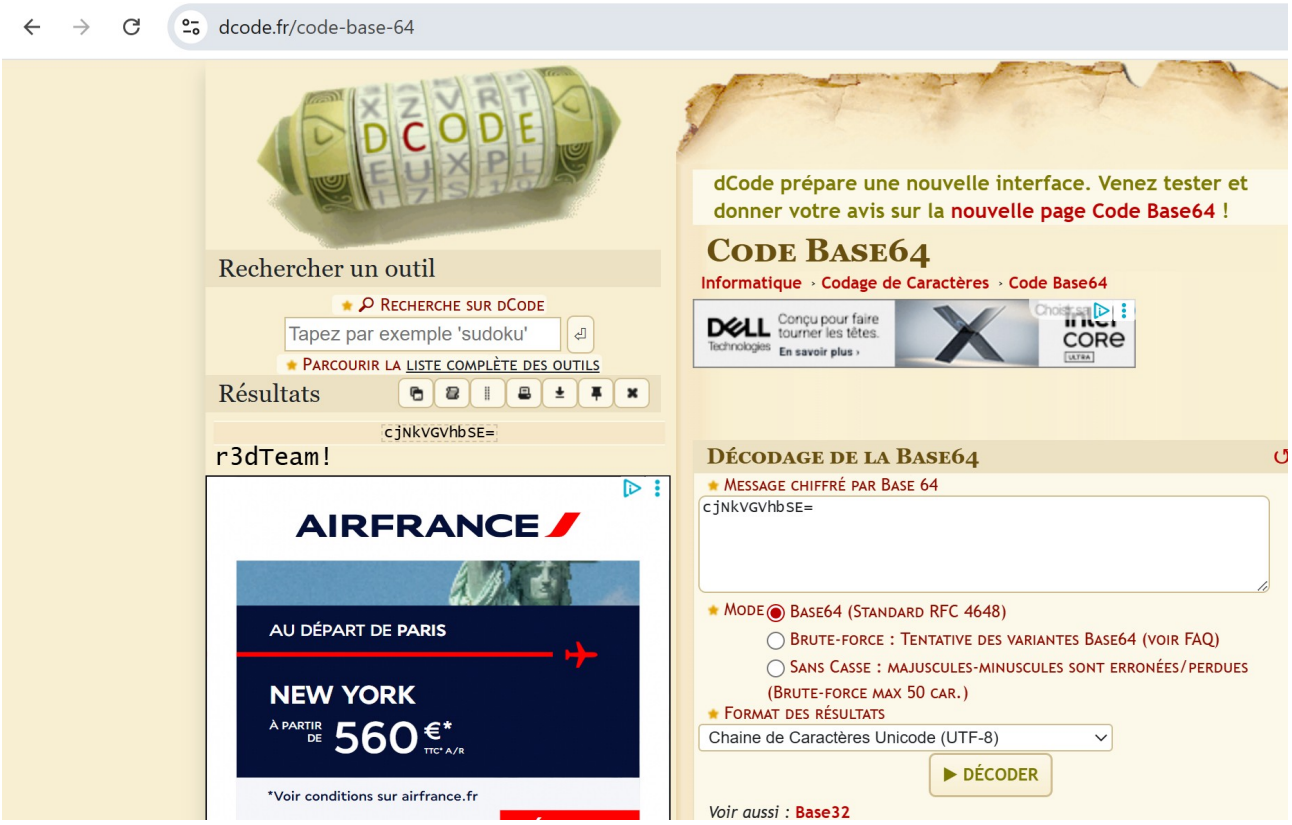
```
┌──(kali㉿kali)-[~]
└─$ sudo nano wordlist_url.txt
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.110.64/ -w wordlist_url.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.110.64/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                wordlist_url.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
robots.txt           (Status: 200) [Size: 237]
Progress: 51 / 51 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
└─$ ncp_crypt -decrypt -password c3RhZ2lhaXJl
ncp_crypt: command not found

┌──(kali㉿kali)-[~]
└─$ sudo ncp_crypt -decrypt -password c3RhZ2lhaXJl
[sudo] password for kali:
sudo: ncp_crypt: command not found

┌──(kali㉿kali)-[~]
└─$
```

du coup on ajoute robots.txt que j'ai trouver à l'URL et on obtient l'utilisateur et le mot de passe mais les deux sont chiffrés.

Non sécurisé 192.168.110.64/robots.txt

```
# robots.txt
User-agent: *
Disallow: /admin/
Disallow: /backup/
Disallow: /config/

# Note interne (ne pas supprimer) :
# AccÃ¨s maintenance - identifiants temporaires chiffrÃ©s :
# Utilisateur : c3RhZ2lhaXJl
# Passe       : cjNkVGVhbSE=
```

Comme les utilisateurs et le mot de passe sont chiffrés il va falloir les déchiffrer, pour déchiffrer il va d'abord falloir trouver avec quel type d'encodage il à été fait. Les logins été chiffrées en code base 64 ensuite il à suffit de les déchiffrer.



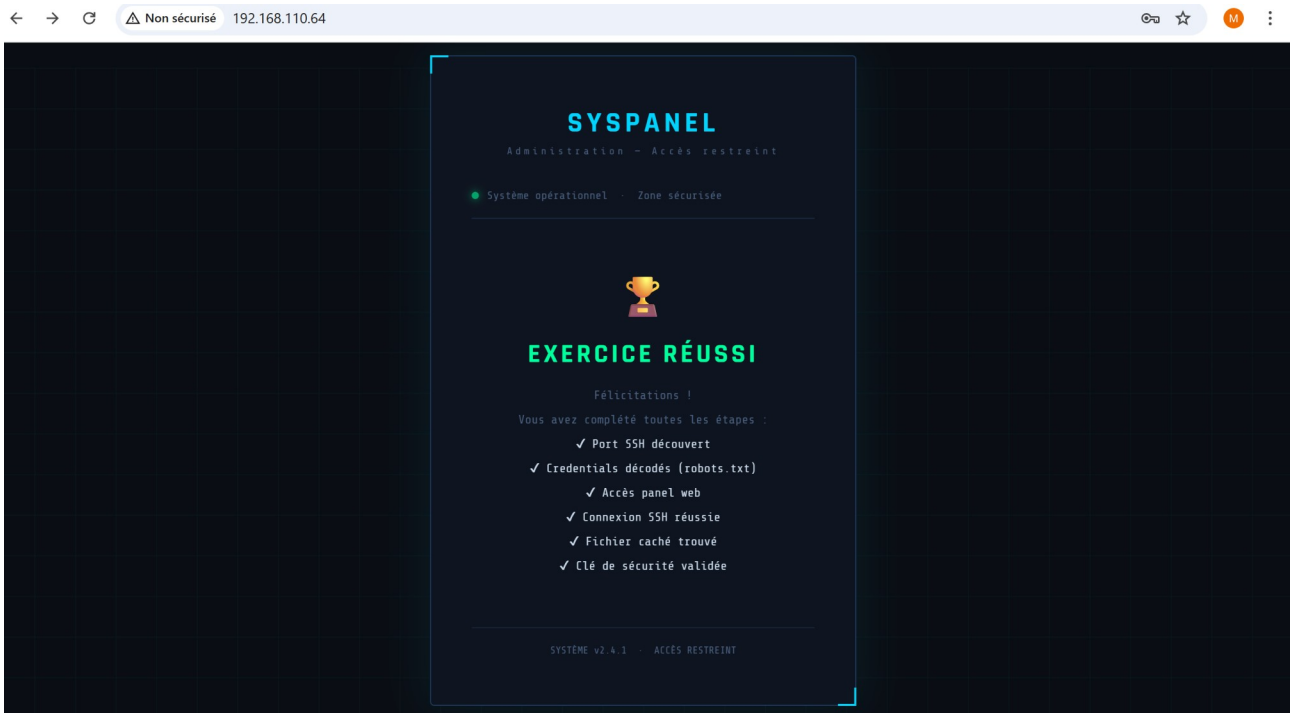
J’ai donc tester la connexion en ssh en précisant bien le de se connecter au port 2277 que j’avais trouver précédemment.

```
┌──(kali㉿kali)-[~]
└─$ ssh stagiaire@192.168.110.64 -p 2277
stagiaire@192.168.110.64's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of mar. 14 avril 2026 07:35:32 UTC

  System load:  0.0               Processes:               108
  Usage of /:   6.9% of 97.87GB   Users logged in:         1
  Memory usage: 9%                IPv4 address for ens18: 192.168.110.64
  Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

La maintenance de sécurité étendue pour Applications n'est pas activée.

60 mises à jour peuvent être appliquées immédiatement.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgrada
ble

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémen
taires.
Visitez https://ubuntu.com/esm ou executez : sudo pro status


*** Le système doit être redémarré ***
Last login: Mon Apr 13 09:56:34 2026 from 192.168.110.77
stagiaire@test:~$ cd /etc
```

Après m’être connecté en ssh il ma fallu trouver la clé de sécurité pour pouvoir me connecter sur le site.Pour se faire j’ai utiliser la commande grep avec le mot « KEY » ce qui cherche le mot « KEY » dans les fichiers et j’ai la clé du coup qui s’affiche.

```
stagiaire@test: ~
Session  Actions  Edit  View  Help
Password:
su: Authentication failure
stagiaire@test:/etc/ssh$ grep -R "KEY" .
grep: ./ssh_host_ed25519_key: Permission denied
grep: ./ssh_host_ecdsa_key: Permission denied
grep: ./sshd_config.d/50-cloud-init.conf: Permission denied
grep: ./ssh_host_rsa_key: Permission denied
stagiaire@test:/etc/ssh$ su
Password:
su: Authentication failure
stagiaire@test:/etc/ssh$  grep -R "KEY" .
grep: ./ssh_host_ed25519_key: Permission denied
grep: ./ssh_host_ecdsa_key: Permission denied
grep: ./sshd_config.d/50-cloud-init.conf: Permission denied
grep: ./ssh_host_rsa_key: Permission denied
stagiaire@test:/etc/ssh$ LS
LS: command not found
stagiaire@test:/etc/ssh$ ls
moduli          sshd_config.d      ssh_host_rsa_key
ssh_config      ssh_host_ecdsa_key     ssh_host_rsa_key.pub
ssh_config.d    ssh_host_ecdsa_key.pub ssh_import_id
sshd_config     ssh_host_ed25519_key
sshd_config.bak ssh_host_ed25519_key.pub
stagiaire@test:/etc/ssh$ cd
stagiaire@test:~$ grep -R "KEY" .
./documents/rapports/2024/.tmp/.key:CTF_KEY=X7K2-P9QM-4NRW-BTYZ
./.bash_history:grep -R "KEY" .
stagiaire@test:~$
```

Et pour finir j’ai rentré la clé de sécurité que j’ai trouver et j’ai donc réussi à me connecter et j’ai fini l’exercice de test.



Accéder au serveur depuis le drive sans utiliser ssh avec reverse shell